SAVEETHA
INSTITUTE OF MEDICAL AND TECHNICAL SCIENCES
(Declared as Deemed to be University under Section 3 of UGC Act 1956)

COMPUTER SCIENCE AND ENGINEERING

Nov – 2026

ASSIGNMENT – 1

Name : T.Raju
Reg_No : 192465038

Course Code : **CSA63**

Course Name : **THREAT INTELLIGENCE AND NETWORK SECURITY**

Max Marks**: 50**

Answer all the Questions

1	A regional hospital network stores patient records, runs an online appointment portal and uses networked diagnostic machines. In one month the hospital faces four incidents: (i) an employee e-mails a spreadsheet of patient details to the wrong recipient, (ii) ransomware encrypts the records server, (iii) a technician alters a lab report without authorisation, and (iv) a flood of requests makes the appointment portal unreachable. Apply the fundamentals of network security to this case. Explain the three goals of the CIA triad and the related goals of authentication, non-repudiation and accountability; map each incident to the goal or goals that it violates with a reason; and prepare a table that gives, for each goal, two preventive controls and one detective control that the hospital should adopt. Discuss how the hospital should balance the three goals when they conflict (for example, tight access control versus emergency access to records).	(10)	(CO1)	(BL3)
2	An online shopping company discovers that an attacker first sent a phishing e-mail to a customer-support agent, used the stolen password to log in to the internal network, moved across to the order database server, and copied customer data to an external server. Analyse the incident by classifying the types of network threats involved (malware, phishing, spoofing, sniffing, man-in-the-middle, denial of service, SQL injection and insider threats), stating which of them are passive and which are active, and identifying the likely threat actor (cybercriminal, hacktivist, nation-state or insider) with reasons. Prepare an attack-chain table that gives, for each stage, the threat, the weakness exploited, the impact on confidentiality, integrity or availability, and one control that would have stopped or detected the attack at that stage. Discuss which weaknesses were technical and which were human or procedural.	(10)	(CO1)	(BL4)

3	A security analyst at a mid-size company notices that the firewall log shows 300 failed login attempts to the VPN gateway within ten minutes from one external IP address, and that the same address appears in a public threat-sharing report as part of a credential-stuffing campaign. Using this example, explain what threat intelligence is and how it differs from raw data and information, by showing how the log entry is converted step by step into actionable intelligence. Describe the	(10)	(CO1)	(BL3)
	characteristics of good threat intelligence (timely, accurate, relevant, contextual and actionable), explain how threat intelligence changes a security team from reactive to proactive, and discuss the benefits and the limitations (for example, false positives, information overload and stale indicators) of using threat intelligence in cybersecurity.			
4	A retail chain learns that a competitor has suffered a point-of-sale malware breach. The security manager must decide how to respond and wants to present suitable threat intelligence to three groups: the Chief Information Security Officer and the board, the SOC manager, and the incident handlers and network administrators. Analyse how strategic, tactical and operational threat intelligence apply to this situation. For each type, state the question that it answers, the audience, the time horizon and the sources, and give one deliverable that you would prepare for this case (for example, a risk briefing, a report of attacker techniques and tools, a warning about an expected campaign, and a list of technical indicators). Classify the following items as strategic, tactical or operational with a reason: an annual report on ransomware trends in retail, a description of how the attacker moves from stolen vendor credentials to the POS servers, an advance warning of a planned attack on the retailer's holiday sales, and a list of malicious domains. Discuss what the company would lose if it relied on only one type.	(10)	(CO1)	(BL4)
5	A software-as-a-service company wants to set up a threat intelligence capability and begins with the requirement: "Are we likely to be targeted by credential-stuffing and ransomware groups in the next six months?" Evaluate how the threat intelligence lifecycle can be applied to answer this requirement. Describe the activities, tools and outputs of the planning and direction, collection, processing, analysis, dissemination and feedback phases, including how priority intelligence requirements are written and how information-sharing markings such as the Traffic Light Protocol are used. Then evaluate the applications of threat intelligence in the IT industry (for example, incident response, threat hunting, vulnerability and patch prioritisation, third-party risk assessment and executive risk reporting), and recommend four measures (for example, mean time to detect, mean time to respond, the percentage of alerts enriched with intelligence and the false-positive rate) to judge whether the programme is delivering value.	(10)	(CO1)	(BL5)

1. Fundamentals of Network Security and the CIA Triad

Network security protects the hospital's systems, patient information and services from unauthorised access, misuse, modification and disruption. The main foundation is the CIA triad: Confidentiality, Integrity and Availability.

A. Three goals of the CIA triad

- Confidentiality: Information must be seen only by authorised people. Example: only authorised doctors should view patient records.
- Integrity: Information must remain correct, complete and unchanged unless an authorised person makes a valid change. Example: laboratory reports must not be altered without permission.
- Availability: Systems and information must be accessible to authorised users whenever required. Example: doctors must be able to access records and patients must be able to book appointments.

B. Related security goals

- Authentication: Confirms the identity of a user or device before access is given.
- Non-repudiation: Provides proof of an action so that a person cannot reasonably deny having performed it. Digital signatures and secure audit records can support it.
- Accountability: Makes it possible to trace actions to a particular user or system through logs, monitoring and audit trails.

C. Mapping the four incidents to security goals

Incident	Goal violated	Reason
Patient spreadsheet sent to the wrong recipient	Confidentiality	An unauthorised recipient receives private patient information.
Ransomware encrypts the records server	Availability and Integrity	Staff cannot access records; encrypted or damaged records may no longer be trustworthy.
Technician changes a lab report without authorisation	Integrity, Accountability and Authentication	The report is changed improperly; access controls or identity verification may have failed, and the action must be traceable.
Flood of requests makes appointment portal unreachable	Availability	Legitimate patients cannot use the appointment service.

D. Preventive and detective controls

Security goal	Two preventive controls	One detective control
Confidentiality	Role-based access control (RBAC); encryption of records and e-mails	Data-loss prevention (DLP) alerts for unusual or external sharing
Integrity	Multi-factor authentication and least-privilege permissions; file/database integrity checks and signed records	Audit-log monitoring for unauthorised changes to patient or lab records
Availability	Regular tested backups and network redundancy; DDoS protection, rate limiting and resilient infrastructure	Availability monitoring and alerts for traffic spikes, service failures or unusual resource use
Authentication	MFA; strong password policy and secure account recovery	Alerts for repeated failed logins and unusual sign-in locations
Non-repudiation	Digital signatures for critical reports; tamper-resistant timestamped records	Review of signed transaction and audit records
Accountability	Unique user accounts; centralised logging with protected log storage	SIEM correlation and periodic audit-log review

E. Balancing the three goals

The hospital should use risk-based security. Strict access control protects confidentiality, but an emergency doctor may need immediate access to a patient's records. The hospital can provide a controlled "break-glass" emergency account: access is granted only when necessary, the reason is recorded, the activity is logged and the access is reviewed afterwards. Backups and recovery procedures protect availability without allowing everyone unrestricted access. Security policies should therefore protect patient privacy while ensuring that critical care is not delayed.

2. Analysis of the Online Shopping Company Attack

The incident is a multi-stage attack. The attacker tricks a support agent, steals the login password, enters the internal network, reaches the order database and copies customer data outside the company.

A. Classification of network threats

Threat type	Meaning and relevance to this incident	Passive or active
Phishing	A fake e-mail tricks the support agent into revealing a password. This is directly involved.	Active
Spoofing	An attacker may pretend to be a trusted sender, website or user. It may support the phishing stage, but is not confirmed by the facts.	Active
Malware	Malicious software may be used to steal credentials or maintain access. No malware is confirmed in the given facts.	Active
Sniffing	Capturing network traffic to obtain data. Not confirmed in this incident.	Passive when only observing traffic
Man-in-the-middle	Secretly intercepting or altering communication between two parties. Not confirmed in the facts.	Active if communication is altered; passive interception may also occur
Denial of service	Overwhelming a service so legitimate users cannot access it. Not reported in this incident.	Active
SQL injection	Inserting malicious SQL into an application input to manipulate a database. Not reported in this incident.	Active
Insider threat	A trusted employee intentionally or accidentally misuses access. The support agent appears to be a victim, not necessarily an insider attacker.	Can be active or accidental; depends on behaviour

Passive threats mainly observe or collect information without changing systems, such as sniffing. Active threats attempt to deceive, modify, disrupt or gain unauthorised access, such as phishing, spoofing, malware, SQL injection and denial of service.

B. Likely threat actor

The most likely actor is a cybercriminal or financially motivated criminal group. The attacker steals customer data and transfers it to an external server, which may be used for resale, fraud or extortion. A nation-state or hacktivist is less likely because the described activity does not show espionage or political motivation. An insider is also less likely because the support agent's password was stolen through phishing.

C. Attack-chain analysis

Stage	Threat	Weakness exploited	CIA impact	Control
1. Phishing e-mail	Phishing / possible spoofing	Poor e-mail filtering, limited awareness or failure to verify the sender	Confidentiality: password is exposed	Secure e-mail gateway, anti-phishing protection and user awareness training
2. Password used to log in	Credential theft and account compromise	Password-only login, reused or weak password, no MFA	Confidentiality and potentially integrity	MFA, password screening and risk-based login alerts
3. Movement to database server	Lateral movement / unauthorised access	Excessive permissions, flat network or weak segmentation	Confidentiality and integrity	Network segmentation, least privilege and endpoint detection
4. Customer data copied externally	Data exfiltration / possible sniffing only if traffic was captured	Weak database access monitoring and no effective outbound data controls	Confidentiality	DLP, database activity monitoring and egress filtering

D. Technical versus human and procedural weaknesses

- Technical weaknesses: lack of MFA, weak password controls, poor network segmentation, excessive database permissions, insufficient endpoint monitoring and weak data-loss controls.
- Human weaknesses: the support agent may not have recognised the phishing message or verified the sender before responding.
- Procedural weaknesses: inadequate phishing training, weak credential-handling rules, lack of access reviews, and insufficient incident reporting and response procedures.

3. Threat Intelligence: From Raw Data to Actionable Intelligence

A. Meaning of threat intelligence

Threat intelligence is information about existing or emerging cyber threats that has been collected, checked and analysed so that an organisation can make security decisions. It explains who may attack, how they may attack, what they may target and what action the organisation should take.

Stage	Meaning	Hospital/company example
Raw data	Unprocessed facts with little meaning by themselves.	One firewall log entry showing a failed VPN login from an IP address.
Information	Data organised to show a pattern or relationship.	300 failed logins from the same external IP address within ten minutes.
Threat intelligence	Analysed information placed in context and connected to a decision.	The IP is also reported in a credential-stuffing campaign; block or rate-limit it, check for successful logins and reset exposed credentials where necessary.

B. Converting a log entry into actionable intelligence

- 1. Collect: The firewall records 300 failed VPN login attempts from one external IP address in ten minutes.
- 2. Organise: The analyst groups the events by source IP, time, username and target VPN gateway.
- 3. Enrich: The IP address is compared with trusted threat-sharing reports and internal security records.
- 4. Analyse: The repeated attempts and external campaign report suggest credential stuffing rather than normal user error.
- 5. Assess impact: The attacker may be testing stolen passwords and could gain access if any credential works.
- 6. Recommend action: Apply rate limiting or blocking, enforce MFA, check for successful logins, alert the SOC and review affected accounts.

C. Characteristics of good threat intelligence

- Timely: Delivered early enough to prevent or reduce an attack.
- Accurate: Verified and supported by reliable evidence, with uncertainty clearly stated.
- Relevant: Related to the organisation's systems, industry, users and risks.
- Contextual: Explains why an indicator or technique matters, not just what it is.
- Actionable: Provides a practical step, such as blocking an indicator, patching a weakness or hunting for a technique.

D. Moving from reactive to proactive security

A reactive team acts after an incident, for example after a VPN account has been compromised. A proactive team uses intelligence to identify likely attackers, monitor their techniques, strengthen exposed systems, hunt for warning signs and block known malicious infrastructure before a major incident occurs.

E. Benefits and limitations

Benefits	Limitations
Earlier warning of campaigns and emerging threats.	False positives may cause legitimate activity to be blocked.
Better prioritisation of vulnerabilities and security work.	Large volumes of feeds can create information overload.
Faster incident investigation and response.	Indicators such as malicious IP addresses and domains can become stale.
Improved threat hunting and security awareness.	Threat feeds may be incomplete, inaccurate or biased.
Better decisions for management and risk planning.	Intelligence requires skilled analysts, tools and ongoing maintenance.

Threat intelligence is most useful when it is continuously validated and connected to clear actions. An IP address should not be blocked blindly if the evidence is weak; analysts should consider confidence, context and business impact.

4. Strategic, Tactical and Operational Threat Intelligence

A point-of-sale (POS) malware breach at a competitor is a warning that the retail chain may face a similar threat. Different groups need different levels of intelligence to make decisions.

Type	Question answered	Audience	Time horizon	Typical sources	Deliverable for this case
Strategic	What is the overall business risk and how may it change?	CISO, board and senior management	Months to years	Industry reports, government advisories, business risk assessments and sector analysis	Board risk briefing on POS malware trends, potential financial/reputation impact and investment priorities
Tactical	How do attackers operate and what methods do they use?	SOC manager, security architects and security leads	Weeks to months	MITRE ATT&CK, malware analysis, incident reports, security research and threat-group profiles	Report describing techniques such as stolen vendor credentials, lateral movement and POS malware deployment
Operational	What specific threat activity is happening, where and when?	Incident handlers, SOC analysts and network administrators	Hours to days	Live threat feeds, SIEM alerts, DNS/firewall logs, sandbox results and trusted sharing groups	Urgent warning with malicious domains, IP addresses, file hashes and detection steps

A. Classification of the given items

Item	Type	Reason
Annual report on ransomware trends in retail	Strategic	It describes long-term industry patterns and business-level risk.
Description of how an attacker moves from stolen vendor credentials to POS servers	Tactical	It explains attacker methods and techniques that defenders can prepare for.
Advance warning of a planned attack on the retailer's holiday sales	Operational	It gives a time-sensitive warning about a specific expected campaign or event.
List of malicious domains	Operational	It provides technical indicators that defenders can use for immediate blocking, monitoring or hunting.

B. Why all three types are needed

- If the company uses only strategic intelligence, management may understand the risk but the SOC may not know which techniques or indicators to detect.
- If it uses only tactical intelligence, defenders may understand attacker methods but management may not know the business impact or investment required.
- If it uses only operational intelligence, the team may block current indicators but fail to understand the wider campaign, attacker methods or long-term risk.

Therefore, strategic intelligence guides investment and policy, tactical intelligence improves defensive methods, and operational intelligence supports immediate detection and response. They work together to provide complete protection.

5. Threat Intelligence Lifecycle and Its Applications

The SaaS company wants to know whether it is likely to be targeted by credential-stuffing and ransomware groups in the next six months. The threat intelligence lifecycle provides a structured way to answer this requirement.

A. Planning and direction

The company first defines what it needs to know, who will use the intelligence and what decisions it should support. It should create Priority Intelligence Requirements (PIRs), which are clear questions ranked by importance.

- Example PIR 1: Which credential-stuffing groups or campaigns have targeted SaaS providers during the last six months?
- Example PIR 2: What exposed login services, authentication weaknesses or leaked credentials could make our company a target?
- Example PIR 3: Which ransomware groups target SaaS providers or their cloud and identity infrastructure, and what early indicators do they use?
- Output: Approved PIR list, scope, six-month time period, owners, collection plan and reporting schedule.

B. Collection

Relevant data is gathered from internal and external sources.

- Internal sources: authentication logs, VPN and firewall logs, endpoint alerts, cloud audit logs, vulnerability scans and incident tickets.
- External sources: government and CERT advisories, trusted threat-intelligence feeds, information-sharing communities, vendor reports and public research.
- Tools: SIEM, EDR, vulnerability scanners, threat-feed platforms and log-management systems.
- Output: Collected logs, indicators, reports and campaign information.

C. Processing

Collected data is cleaned and organised so that it can be analysed. Duplicate records are removed, timestamps are standardised, and indicators are checked and converted into usable formats.

- Tools: SIEM parsing and correlation, threat-intelligence platforms, data normalisation tools and malware sandboxes.
- Output: Structured and enriched records, such as validated IP addresses, domains, file hashes, timestamps and related events.

D. Analysis

Analysts connect the processed data to the company's environment and estimate the likelihood and impact of attacks. They look for trends such as repeated login failures, leaked credentials, exposed services, ransomware techniques and weaknesses in backup or identity systems.

- Tools and methods: MITRE ATT&CK mapping, SIEM correlation, attack-surface review, risk scoring and analyst investigation.
- Output: An assessment of the likelihood of credential stuffing and ransomware in the next six months, confidence levels, key risks and recommended actions.

E. Dissemination

The findings are delivered to the people who need them in a clear format and within the right time.

- Executives receive a short risk briefing with business impact and required investment.
- The SOC receives campaign summaries, detection logic and hunting priorities.
- System administrators receive indicators, hardening actions and patch priorities.
- Output: Reports, alerts, dashboards, detection rules and recommended actions.

F. Feedback

The company asks users whether the intelligence was useful, whether the recommendations were completed and what further questions have appeared. It updates PIRs and collection priorities based on incidents, changing threats and user feedback.

- Output: Updated PIRs, improved collection plan, lessons learned and programme performance measures.

G. Traffic Light Protocol (TLP)

The Traffic Light Protocol (TLP) is used to mark how widely information may be shared. The recipient must follow the marking attached to the information.

Marking	Sharing meaning
TLP:RED	For named recipients only; do not share further.
TLP:AMBER	Limited sharing within the recipient's organisation on a need-to-know basis.
TLP:AMBER+STRICT	Share only within the recipient's organisation.
TLP:GREEN	May be shared with the community, but not publicly.
TLP:CLEAR	May be shared publicly, subject to applicable rules and copyright.

The company should preserve TLP markings when forwarding intelligence and ensure staff understand the sharing limits. TLP controls distribution; it does not by itself prove that the information is accurate.

H. Applications of threat intelligence in the IT industry

- Incident response: Helps responders identify attacker infrastructure, likely methods and the scope of an incident.
- Threat hunting: Gives analysts hypotheses and indicators to search for hidden attacker activity.
- Vulnerability and patch prioritisation: Helps prioritise weaknesses that are actively exploited and relevant to the company.

- Third-party risk assessment: Helps assess whether vendors or service providers are exposed to threats that could affect the company.
- Executive risk reporting: Converts technical threats into business risks, likely impact and investment decisions.

I. Four measures to evaluate the programme

Measure	What it measures	Why it is useful
Mean Time to Detect (MTTD)	Average time between the start of a security incident and its detection.	A reduction suggests the team is identifying threats sooner.
Mean Time to Respond (MTTR)	Average time taken to contain or respond to a detected incident.	A reduction suggests intelligence is helping responders act faster.
Percentage of alerts enriched with intelligence	Number of relevant alerts enriched with threat context divided by total relevant alerts, multiplied by 100.	Shows whether intelligence is being integrated into daily security operations.
False-positive rate	Percentage of alerts or indicators incorrectly treated as malicious.	A lower rate suggests better validation and less wasted analyst effort.

The company should measure these values regularly and compare them with a baseline. The measures should be interpreted together: a high enrichment percentage is not useful if the intelligence is inaccurate or creates excessive false alarms.

Conclusion

A well-managed threat intelligence programme helps the SaaS company make informed decisions about credential stuffing and ransomware risks. By following all lifecycle phases, using TLP correctly, sharing intelligence with the right teams and measuring results, the company can improve prevention, detection and response over the next six months.